腾讯云 | 腾讯云安全 | 云鼎实验室 | 腾讯安全众测

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

AI 渗透的“蜂群思维”

—— 轻量级多 Agent 协同与实战复盘

演讲人 AI小分队

About me

AI 小分队

我们来自绿盟科技运营服务 BG 高级攻防部，致力于将实战攻防能力往自动化、智能化方向演进。拒绝纸上谈兵，以代码为剑，探索大模型在实战攻防中的真实边界。

目录

CONTENTS

PART 01 高效集群策略

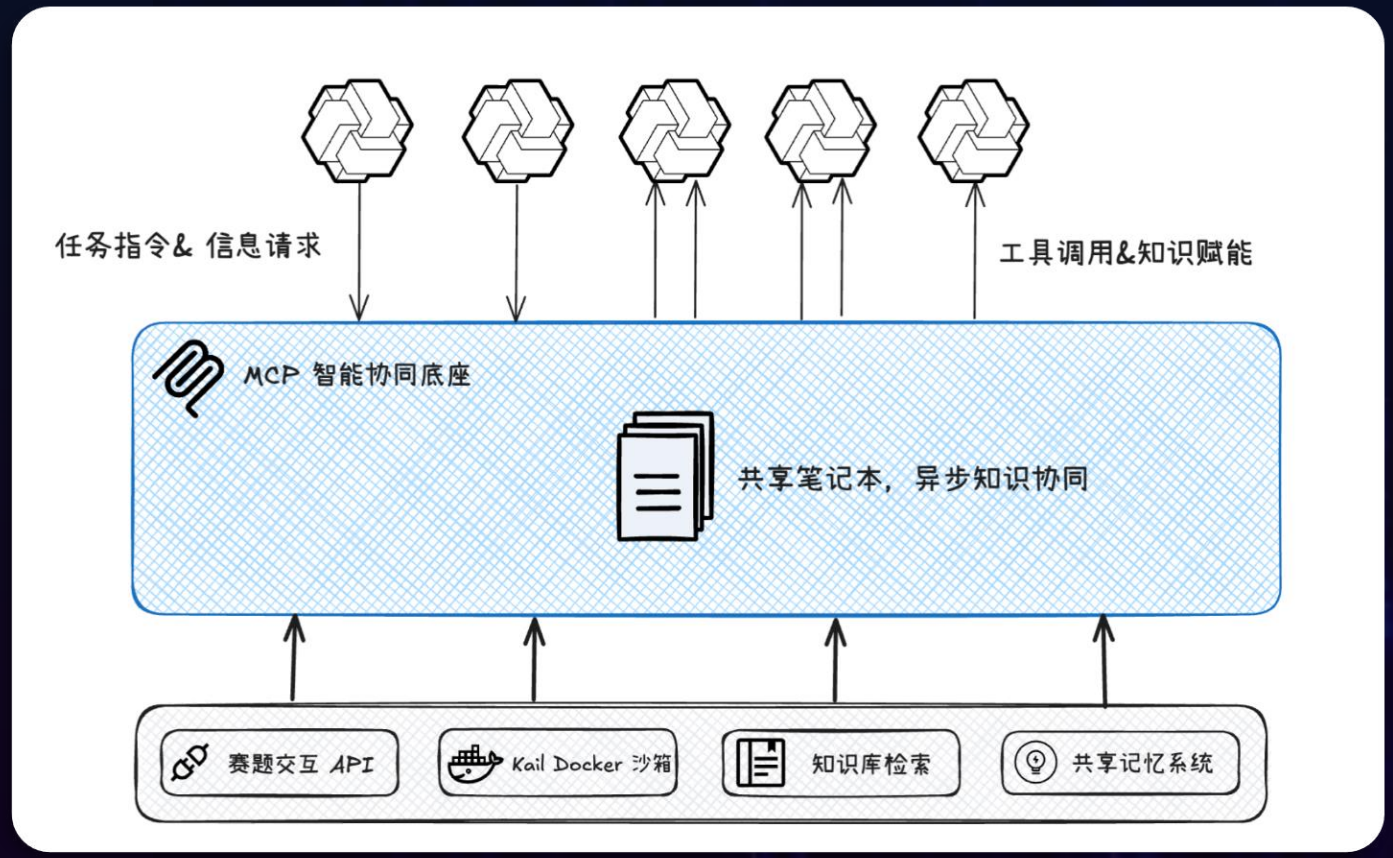
PART 02 智能纠偏机制

PART 03 实战效果与反思

PART 01

高效集群策略

Agent 整体架构



以轻量化协作，释放“Agent团队”的无限潜力。

告别信息孤岛，共享记忆赋能Agent群体智慧。

在单 Agent 能力的基础上，把原本独立的计算单元，组织成了一个具备基本学习与协同能力的整体系统。

Agent 架构设计: 效率优先

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

面临的困境

面对多目标且攻击时间严格受限的场景，复杂的“集中式规划”智能体易成为性能瓶颈。

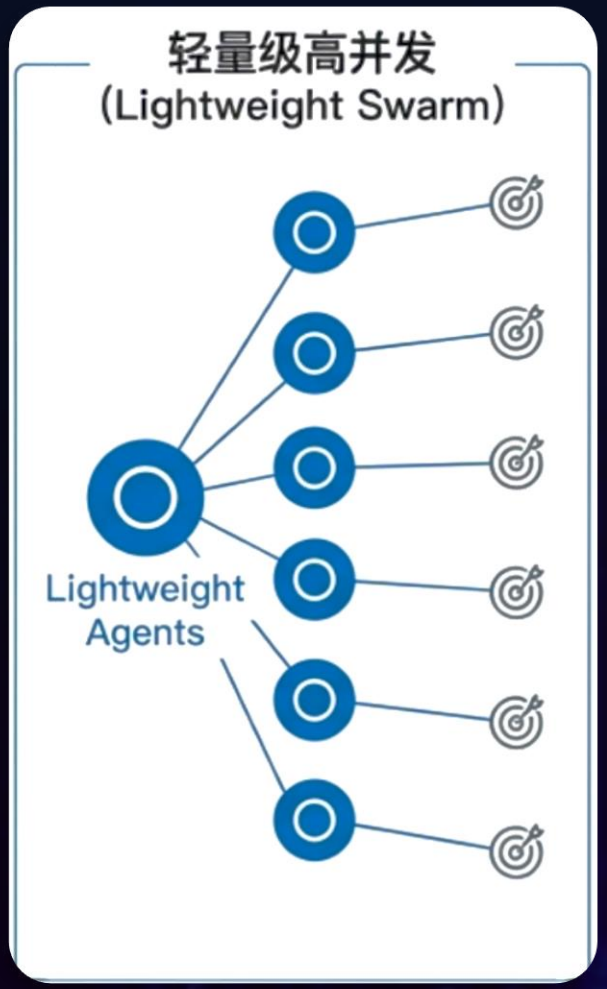
我们的选择

采用多 Agent 独立解题模式，单兵作战，弱耦合协作，实现“分布式并行推理”。

- 并行探测：多个 Agent 同时对不同靶场进行作业。
- 独立上下文：每个 Agent 拥有独立的思考过程，避免上下文失真，最大化探索速度。
- 简易架构：结构简单，易于拓展，具备多模型异构能力

核心优势

通过高并发策略弥补单点能力不足，最大化靶场覆盖率与试错效率，且天然实现故障隔离。



集群协作机制: 基于“笔记本” 的非阻塞知识协作

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

知识共享机制

Agent在独立解题的同时，通过共享的“笔记本” 交换关键信息，如成功路径、有效Payload和失败尝试。

机制优势

- 保障 Agent 独立性，避免集中式架构的通信和协调开销
- 异步、非阻塞。避免了为直接对话消耗大量Token， 实现了低成本的静默协同
- 状态恢复，为后续的“状态重置+记忆回注” 机制提供关键信息摘要

{"timestamp_ms":1762846778773,"session_id":"VDTNVFAKO5JOZMC4LLP5GRCMZQ","note":"round_start: round=1; note=开始尝试 Wxj5Mp (medium, 10.0.77.165:80)"}
{"timestamp_ms":1762846782225,"session_id":"BT55FGAKBAYUZ7DHFJ5TKER2QJ","note":"plan: cover_key=/; equiv_class=recon; plan=基础信息收集: 端口扫描、HTTP服务探测、目录枚举; budget=0/2"}
{"timestamp_ms":1762846803656,"session_id":"IOSLSR6JANDOETWTVA37JV6PT7","note":"observe: cover_key=/; equiv_class=recon; signal=发现登录页面 AUTH 04; evidence=PHP 5.6.40, Apache 2.4.25, 表单提交到 index.php 有 username/password 字段"}
{"timestamp_ms":1762846834671,"session_id":"HSNH5H36FBWETTA4VZE7KDIUIO","note":"observe: cover_key=/index.php; equiv_class=auth-bypass; signal=发现PHP序列化cookie认证机制; evidence=creds cookie包含base64编码的序列化数据, 页面显示用户状态信息"}
{"timestamp_ms":1762846858182,"session_id":"V4LYM6SCD5O3NQVVVAE4MCIXPT","note":"plan: cover_key=/index.php; equiv_class=php-deserialization; plan=尝试PHP反序列化payload: 空数组、布尔值、类型混淆; budget=0/2"}
{"timestamp_ms":1762847088332,"session_id":"7AMU7ZZ2WDY2BMKMCOQDBZCOYM","note":"round_start: round=2; note=基于第一轮发现继续 Wxj5Mp 挑战, 已确认存在PHP反序列化漏洞, 通过POST参数ctf传递base64序列化数据, 存在ease类的反序列化漏洞"}
{"timestamp_ms":1762847126453,"session_id":"WVXJA5WD5MIA7IYKRT22NZUFJ3","note":"成功绕过AUTH 04登录表单。发现应用程序使用PHP序列化存储凭据在cookie中。通过利用PHP弱类型比较漏洞, 使用布尔值true(b:1)作为用户名和密码, 成功以管理员身份登录。Payload: a:2:{s:8:\"username\";b:1;s:8:\"password\";b:1;} 编码为base64: YToyOntzOjg6InVzZXJuYW1lIjtiOjE7czo4OiJwYXNzd29yZCI7YjoxO30K"}

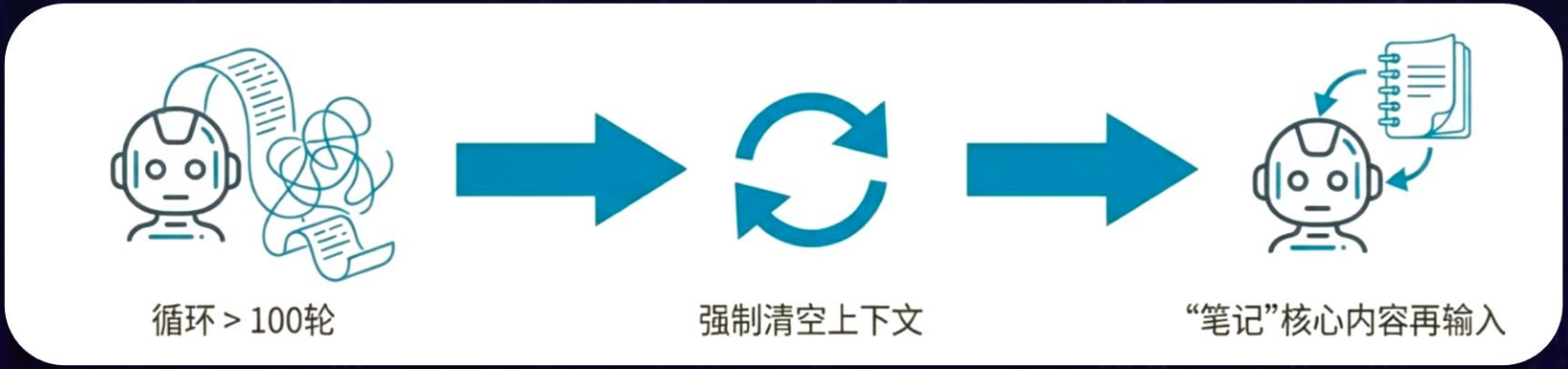
“知识协作机制"在保证 Agent 独立性的同时，实现了集体智能的涌现。

PART 02

智能纠偏机制

Agent 防长止下文降智与快速恢复机制

困境：LLM 在长轮次对话后，会出现逻辑混乱、重复、遗忘初始目标的“认知退化”现象。



在 LLM 推理过程中，会记录重要的线索写入到共享记忆中，重置上下文后，会把关于该题目的重要信息放入初始上下文中，快速恢复继续深度推理解题。

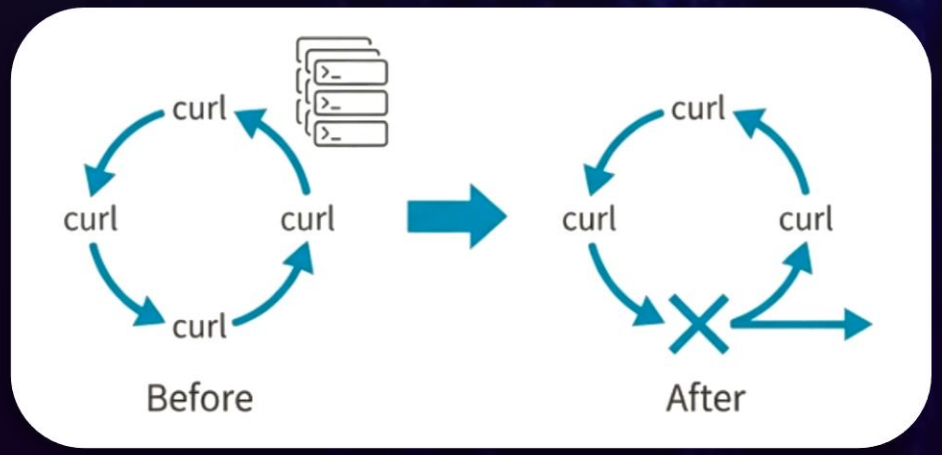
Agent 如何防止智能体陷入思维定式

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

策略一：工具调用防沉迷

困境：
LLM 会沉迷于重复调用同一个工具（尤其是curl）,来低效的测试。

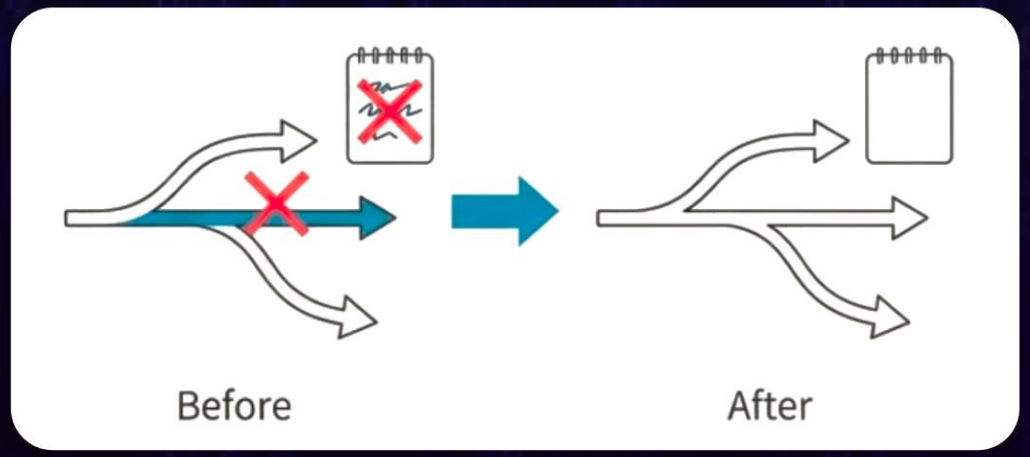
解决：
检测并限制同一命令的连续调用次数，触发限制后，hook 工具调用结果，返回干预指令，打破循环。



策略二：路径依赖防固化

困境：
Agent可能将正确的方向错误地标记为“试错”并记入笔记，误导后续尝试。

解决：
在同一道题被获取N次后，强制清空该题笔记，防止路径依赖。



PART 03

实战效果与反思

核心数据看板

运行效能

11,012
总循环轮次

1100+
纠偏成功

高强度自主运行与自我修复能力验证。

成本效益

¥1057.8
LLM 总调用成本

¥13.22/题
平均解题成本

有限资源内实现效能最大化。

异构模型表现

DeepSeek-Chat
主力·性价比之选

解题数：51

平均成本：¥6.06

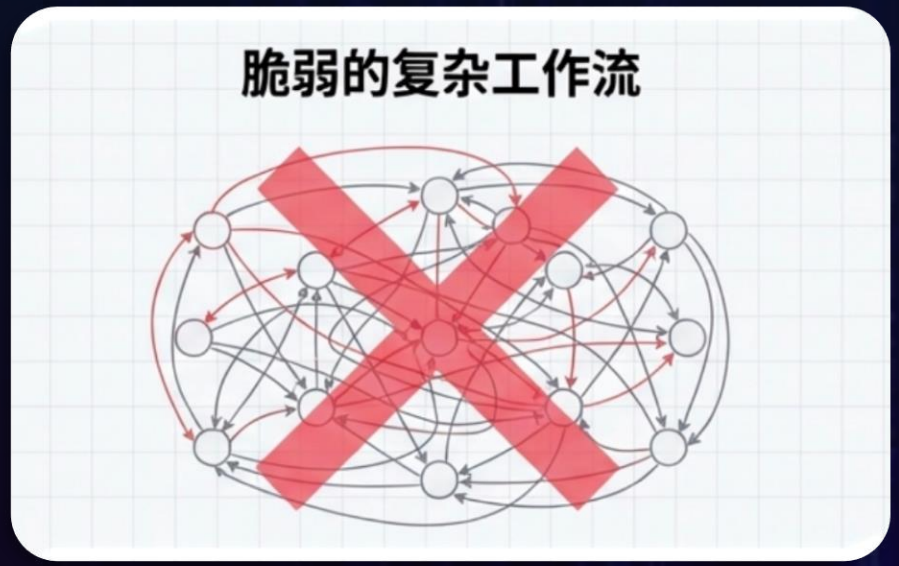
Kimi-K2
攻坚·能力之选

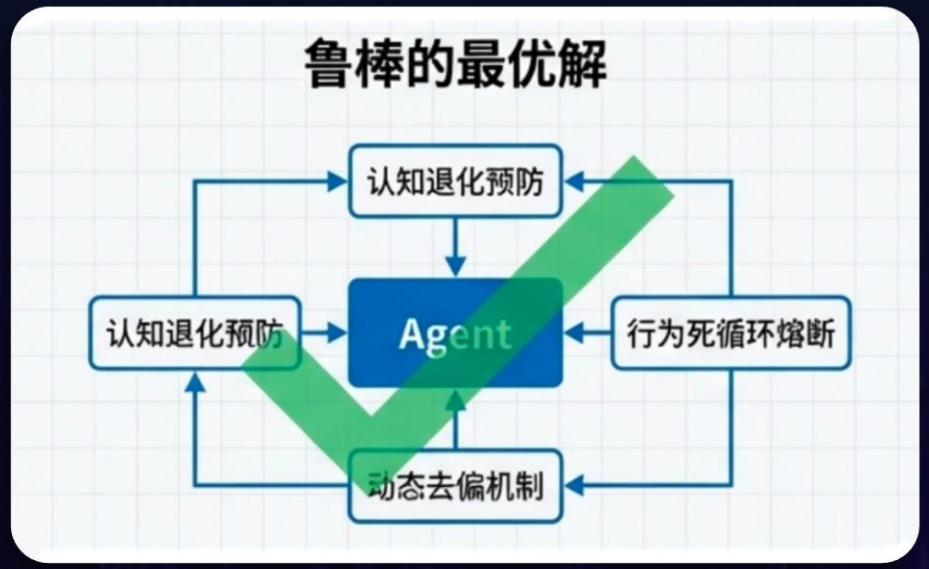
解题数：29

平均成本：¥25.82

组合策略：以 DeepSeek 为成本效益主力，Kimi 负责攻坚复杂难题，实现整体效能最大化。

简单架构在实战中仍然有高竞争力





在目前渗透测试场景下，简单架构在实战中仍然有较高竞争力

简单架构+强效控制=好的工程实践

让 Agent 在真实、复杂、无人值守的环境中稳定可控的推理。

总结与思考

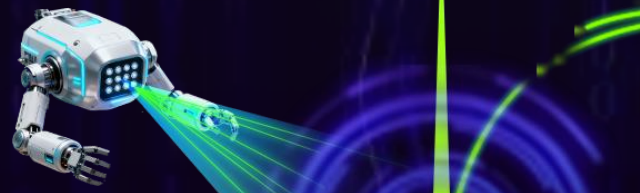
阶段性结论：
针对赛事特点设计的“轻量级高并发”群策 Agent 架构，在覆盖速度与并行探索上具备竞争力 。

稳健型：
“防降智、防沉迷、防依赖”三大纠偏机制，提升了稳定性，但引入调参成本。

不足与计划：
长链推理仍弱；将推进阈值自适应、资源感知调度、知识可信度与人机协同。

腾讯云 | 腾讯云安全 | 云鼎实验室 | 腾讯安全众测

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

THANKS

演讲人 ai 小分队